

SIMATS ENGINEERING

ASSESSMENT TOOL I– INDUSTRY PROBLEM TASK

Course:	Code:	CO: CO5
Duration:	Total Marks: 100	Reg No / Name:192511230

COURSE OUTCOME COVERED

CO5: *Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Instructions: *Answer all questions. Each question carries 20 marks.*

1. A mid-sized financial organization operates a Windows domain network consisting of 150 interconnected systems. During a security incident investigation, it is observed that attackers have exploited NULL sessions, open RPC services, and misconfigured shared folders to gain unauthorized access. Initial analysis indicates that 45% of systems allow anonymous enumeration, and among those, 60% are susceptible to SMB-based lateral movement attacks. Furthermore, each compromised system can attempt to access 3 additional systems, with a success probability of 0.3 per attempt.

Question:

Analyze the extent of the attack by calculating the number of systems compromised during the initial stage of exploitation. Further, estimate the spread of the attack in the second stage due to lateral movement. Based on your analysis, evaluate whether the network is at risk of a large-scale compromise (greater than 70% of total systems), and justify which vulnerability (NULL sessions, RPC exposure, or weak shares) should be prioritized for immediate mitigation.

2. An enterprise network consists of 120 systems, out of which 70 systems expose RPC services to the internal network. A vulnerability scan reveals that 40% of these systems are susceptible to known exploits, and the probability of successful exploitation for each vulnerable system is 0.5. However, each exploitation attempt carries a detection probability of 0.25 due to intrusion detection systems deployed within the network.

Question:

Determine the expected number of systems that can be successfully compromised by an attacker. Additionally, compute the expected number of detection alerts generated during the exploitation process. Based on your results, critically evaluate whether an attacker aiming to remain stealthy would proceed with exploitation or adopt alternative attack strategies, providing justification for your reasoning.

3. A cloud-hosted Linux server is running multiple services exposed to the internet. Security analysis identifies four critical services, with independent probabilities of vulnerability being 0.3, 0.2, 0.25, and 0.15, respectively. It is also observed that the system has weak file permissions, which can be exploited with a probability of 0.5 once initial access is gained.

Question:

Evaluate the probability that at least one service is vulnerable and can be exploited by an attacker. Further, compute the overall probability of a full system compromise, considering both service exploitation and privilege escalation through weak permissions. Based on your findings, analyze whether strengthening file permissions alone would significantly reduce the overall risk, and justify your conclusion.

4. An organization uses Network File System (NFS) to share resources across three internal subnets. Due to improper configuration, unauthorized access probabilities from these subnets are estimated as 0.4, 0.3, and 0.2, respectively. Once access to the NFS share is obtained, the probability of privilege escalation to root access is 0.7.

Question:

Calculate the probability that at least one subnet successfully gains unauthorized access to the NFS share. Subsequently, determine the overall probability of a complete system compromise. Based on your analysis, evaluate the effectiveness of restricting NFS access to a single subnet as a mitigation strategy, and justify your recommendation.

5. An e-commerce platform maintains a database containing 50,000 user records, of which 30% are classified as sensitive. A successful SQL injection attack allows data extraction at a rate of 500 records per second. However, the application firewall detects and blocks the attack after 40 seconds.

Question:

Compute the total number of records that can be extracted before the attack is blocked. Determine the percentage of total data compromised, and estimate the number of sensitive records exposed. Based on your analysis, evaluate the severity of the breach and justify whether the existing detection mechanism is sufficient to protect critical data.

Code of Conduct:

I Poojitha[192511230]_____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning	Mark
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem context	
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts	
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution	
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools	
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis	
Professionalism	5%	Highly professional, well-documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation	

Question 1 — Windows Domain: NULL Sessions, RPC & SMB Lateral Movement

Given: 150 systems on the domain. 45% allow anonymous enumeration. Among those, 60% are susceptible to SMB-based lateral movement. Each compromised system attempts to access 3 additional systems, with a success probability of 0.3 per attempt.

Kali Linux Terminal — Calculation Script

```
poojitha@kali:~$ nano q1_attack_spread.py
poojitha@kali:~$ cat q1_attack_spread.py

#!/usr/bin/env python3
# CO5 - Q1: Windows domain NULL session / SMB lateral movement analysis
```

```

total_systems = 150
anon_enum_rate = 0.45
smb_vuln_rate = 0.60
attempts_per_system = 3
success_prob = 0.30

# Stage 1: initial exploitation via NULL session + SMB lateral movement
anon_systems = total_systems * anon_enum_rate
stage1_compromised = anon_systems * smb_vuln_rate

# Stage 2: lateral movement spread
stage2_new = stage1_compromised * attempts_per_system * success_prob
total_compromised = stage1_compromised + stage2_new
pct_compromised = (total_compromised / total_systems) * 100

print(f'Anonymous-enumeration systems : {anon_systems:.1f}')
print(f'Stage 1 compromised      : {stage1_compromised:.1f}')
print(f'Stage 2 new compromises   : {stage2_new:.2f}')
print(f'Total compromised        : {total_compromised:.2f}')
print(f'Percent of network compromised: {pct_compromised:.2f}%')
print(f'Large-scale risk (>70%)   : {pct_compromised > 70}')

```

```

poojitha@kali:~$ python3 q1_attack_spread.py
Anonymous-enumeration systems : 67.5
Stage 1 compromised      : 40.5
Stage 2 new compromises   : 36.45
Total compromised        : 76.95
Percent of network compromised: 51.30%
Large-scale risk (>70%)   : False

```

Answer & Analysis

Stage 1 (initial exploitation): 45% of 150 systems (67.5) allow anonymous NULL-session enumeration. Of these, 60% (≈ 40.5 systems) are further susceptible to SMB-based lateral movement — this is the initial compromise count.

Stage 2 (lateral movement spread): each of the ~ 40.5 compromised systems attempts 3 further connections at a 0.3 success rate, yielding $40.5 \times 3 \times 0.3 \approx 36.45$ additional compromised systems.

Total after two stages ≈ 76.95 systems, i.e. $\approx 51.3\%$ of the network.

Risk evaluation: 51.3% is below the 70% large-scale-compromise threshold after two stages, but the trajectory is steep — a third lateral-movement cycle would push the network well past 70%. The network should therefore be treated as at imminent risk of large-scale compromise if not remediated immediately.

Priority mitigation: NULL sessions should be prioritized first, since they are the root enabler — disabling anonymous SMB/RPC enumeration (restricting anonymous access, RestrictAnonymous registry policy) collapses the attack surface for both RPC exposure and weak-share abuse that follow from it.

Question 2 — RPC Exposure vs. IDS Detection Probability

Given: 120 systems, 70 expose RPC. 40% of these are vulnerable; exploitation success probability 0.5 per vulnerable system; detection probability 0.25 per exploitation attempt.

Kali Linux Terminal — Calculation Script

```

poojitha@kali:~$ nano q2_rpc_detection.py
poojitha@kali:~$ cat q2_rpc_detection.py

```

```
#!/usr/bin/env python3
# CO5 - Q2: RPC exploitation vs IDS detection trade-off

rpc_exposed = 70
vuln_rate = 0.40
exploit_success = 0.50
detection_prob = 0.25

vulnerable_systems = rpc_exposed * vuln_rate
expected_compromised = vulnerable_systems * exploit_success
expected_alerts = vulnerable_systems * detection_prob

# probability attacker is detected at least once across all attempts
p_no_detect_per_attempt = 1 - detection_prob
p_at_least_one_alert = 1 - (p_no_detect_per_attempt ** vulnerable_systems)

print(f'Vulnerable RPC systems      : {vulnerable_systems:.1f}')
print(f'Expected compromised systems : {expected_compromised:.1f}')
print(f'Expected detection alerts      : {expected_alerts:.1f}')
print(f'P(at least one alert raised) : {p_at_least_one_alert*100:.2f}%')

poojitha@kali:~$ python3 q2_rpc_detection.py
Vulnerable RPC systems      : 28.0
Expected compromised systems : 14.0
Expected detection alerts    : 7.0
P(at least one alert raised) : 99.94%
```

Answer & Analysis

Vulnerable RPC systems = $70 \times 0.40 = 28$. Expected compromised systems = $28 \times 0.5 = 14$.

Expected detection alerts = $28 \times 0.25 = 7$ alerts across the exploitation attempts.

Stealth evaluation: with 28 attempts each carrying a 0.25 detection chance, the probability that the IDS raises at least one alert is $1 - (0.75)^{28} \approx 99.94\%$ — detection is almost certain. An attacker prioritizing stealth would not proceed with this broad, noisy RPC exploitation approach; instead they would favor low-and-slow techniques (targeting a small subset of high-value hosts, using living-off-the-land binaries, or credential-based access) that minimize the number of IDS-visible attempts, even though this yields fewer compromised systems.

Question 3 — Cloud Linux Server: Multi-Service Exploitation & Privilege Escalation

Given: four independent services with vulnerability probabilities 0.30, 0.20, 0.25, 0.15. Weak file permissions allow privilege escalation with probability 0.5 once initial access is gained.

Kali Linux Terminal — Calculation Script

```
poojitha@kali:~$ nano q3_service_compromise.py
poojitha@kali:~$ cat q3_service_compromise.py

#!/usr/bin/env python3
# CO5 - Q3: Probability of service compromise + privilege escalation

service_probs = [0.30, 0.20, 0.25, 0.15]
privesc_prob = 0.50
```

```

p_none_vulnerable = 1.0
for p in service_probs:
    p_none_vulnerable *= (1 - p)

p_at_least_one = 1 - p_none_vulnerable
p_full_compromise = p_at_least_one * privesc_prob

print(f'P(none of the services vulnerable) : {p_none_vulnerable:.4f}')
print(f'P(at least one service vulnerable) : {p_at_least_one*100:.2f}%')
print(f'P(full system compromise)      : {p_full_compromise*100:.2f}%')

poojitha@kali:~$ python3 q3_service_compromise.py
P(none of the services vulnerable) : 0.3570
P(at least one service vulnerable) : 64.30%
P(full system compromise)      : 32.15%

```

Answer & Analysis

$P(\text{at least one service vulnerable}) = 1 - (0.7 \times 0.8 \times 0.75 \times 0.85) = 1 - 0.357 = 0.643 \rightarrow 64.3\%$.

$P(\text{full system compromise}) = P(\text{at least one service exploited}) \times P(\text{privilege escalation}) = 0.643 \times 0.5 = 0.3215 \rightarrow 32.15\%$.

Would fixing permissions alone be sufficient? No. Hardening file permissions removes the privilege-escalation step and drives the full-compromise probability to 0%, but it does nothing to the 64.3% chance that an attacker still gains an initial service-level foothold. That foothold alone (data exposure, service disruption, pivot point) is still a serious risk. Strengthening permissions must be paired with patching/hardening the four exposed services to meaningfully reduce overall risk.

Question 4 — NFS Multi-Subnet Exposure & Root Privilege Escalation

Given: three subnets with unauthorized-access probabilities 0.4, 0.3, 0.2. Once NFS access is gained, privilege escalation to root succeeds with probability 0.7.

Kali Linux Terminal — Calculation Script

```

poojitha@kali:~$ nano q4_nfs_compromise.py
poojitha@kali:~$ cat q4_nfs_compromise.py

#!/usr/bin/env python3
# CO5 - Q4: NFS multi-subnet access + root privilege escalation

subnet_probs = [0.4, 0.3, 0.2]
root_escalation_prob = 0.7

p_none = 1.0
for p in subnet_probs:
    p_none *= (1 - p)
p_at_least_one = 1 - p_none
p_full_compromise = p_at_least_one * root_escalation_prob

# Mitigation: restrict NFS export to the single lowest-risk subnet
restricted_prob = min(subnet_probs)
p_full_compromise_restricted = restricted_prob * root_escalation_prob

print(f'P(at least one subnet gains access) : {p_at_least_one*100:.2f}%')
print(f'P(full compromise, all subnets)   : {p_full_compromise*100:.2f}%')

```

```
print(f'P(full compromise, 1 subnet only) : {p_full_compromise_restricted*100:.2f}%')
```

```
poojitha@kali:~$ python3 q4_nfs_compromise.py
P(at least one subnet gains access) : 66.40%
P(full compromise, all subnets) : 46.48%
P(full compromise, 1 subnet only) : 14.00%
```

Answer & Analysis

$P(\text{at least one subnet gains unauthorized access}) = 1 - (0.6 \times 0.7 \times 0.8) = 1 - 0.336 = 0.664 \rightarrow 66.4\%$.

$P(\text{complete system compromise}) = 0.664 \times 0.7 = 0.4648 \rightarrow 46.48\%$.

Effectiveness of restricting NFS to a single subnet: limiting the export to only the lowest-risk subnet (0.2) reduces the compromise probability to $0.2 \times 0.7 = 14\%$ — a drop of over 32 percentage points. This is a highly effective, low-cost mitigation, though it should be combined with export-level access controls (root_squash, Kerberos authentication) since 14% residual risk is still non-trivial.

Question 5 — SQL Injection Data Exfiltration Rate & Sensitive-Record Exposure

Given: 50,000 user records, 30% classified sensitive. SQL injection extracts data at 500 records/second; the WAF blocks the attack after 40 seconds.

Kali Linux Terminal — Calculation Script

```
poojitha@kali:~$ nano q5_sqli_exfiltration.py
poojitha@kali:~$ cat q5_sqli_exfiltration.py

#!/usr/bin/env python3
# CO5 - Q5: SQL injection exfiltration rate & sensitive data exposure

total_records = 50000
sensitive_rate = 0.30
extraction_rate = 500    # records / second
time_to_block = 40       # seconds

records_extracted = extraction_rate * time_to_block
pct_extracted = (records_extracted / total_records) * 100
sensitive_exposed = records_extracted * sensitive_rate

print(f'Records extracted      : {records_extracted}')
print(f'Percent of database exposed : {pct_extracted:.1f}%')
print(f'Sensitive records exposed  : {sensitive_exposed:.0f}')

poojitha@kali:~$ python3 q5_sqli_exfiltration.py
Records extracted      : 20000
Percent of database exposed : 40.0%
Sensitive records exposed  : 6000
```

Answer & Analysis

Records extracted before blocking = $500 \times 40 = 20,000$ records.

Percentage of total database compromised = $20,000 / 50,000 = 40\%$.

Sensitive records exposed (assuming uniform distribution of the 30% sensitive class) = $0.30 \times 20,000 = 6,000$ records.

Severity assessment: a 40-second detection window allowing 40% of the entire database — including 6,000 sensitive records — to be exfiltrated is a severe breach. A firewall/WAF that only intervenes after 40 seconds and 20,000 records is not sufficient for protecting critical data; the organization should implement query-rate anomaly detection, prepared-statement enforcement, and sub-second automated blocking (WAF rules keyed to abnormal SELECT throughput) to cut the exposure window drastically.